CAIS 2026 WORKSHOP — AGENTIC SOFTWARE ENGINEERING

Hallucination-Resistant CVE Prioritization via Multi-Source Agentic Orchestration

Vendor-Aware CVE Discovery with Evidence Grounding and Abstention Using LangGraph

Darshana Patil · University of the Pacific, Stockton, CA, USA

INTRODUCTION

Security teams spend hours manually cross-referencing patch notes, CVE databases, and community forums to decide what to update and when. Delayed patching of critical vulnerabilities directly increases organizational risk.

This paper presents a **stateful multi-agent retrieval system** that answers natural language security queries by autonomously routing, fetching, and grounding answers across three real-time data sources: the NIST National Vulnerability Database, ReleaseTrain release notes, and Reddit community signals.

The system is built on LangGraph, using a directed acyclic graph of specialized nodes. Each node has a single responsibility. No node sees data it does not need. The result is a pipeline where hallucination is structurally prevented rather than post-hoc corrected.

Our The key contribution is a three-layer evidence grounding architecture: (1) the primary LLM cites evidence IDs, (2) a repair LLM fills gaps in a single batched call, (3) a deterministic fallback uses token overlap scoring. Answers are only shown when at least one layer succeeds.

METHODOLOGY

01 Stage 1 — Intent Classification (Orchestrator Node)
The query is classified as security or out-of-scope before any data is fetched. Out-of-scope queries (install guides, pricing, feature comparisons) receive an immediate redirect with a suggested rephrasing. This prevents the LLM from fabricating answers on topics the data sources cannot support.

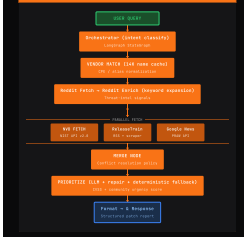
02 Stage 2 — Vendor Extraction (Vendor Match Node)
Query keywords are matched against a cached list of 14,000 known software vendors from ReleaseTrain. An exact-then-substring match returns the canonical vendor name and its dedicated subreddit. This match enables precise API calls instead of broad keyword searches.

03 Stage 3 — Community Enrichment (Reddit Enrich Node)
Reddit posts from the matched subreddit are fetched. First, An LLM reads the post titles and author descriptions to expand vague query terms into specific product keywords. The query "protect 7.0" becomes "ubiquiti protect" and "unifi protect" before any CVE or release data is fetched.

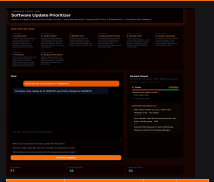
04 Stage 4 — Parallel Data Fetch
Three nodes run concurrently using the enriched keywords: NVD node queries the NIST CVE API with a 120-day window, extracts CVSS scores and severity. ReleaseTrain node uses the vendor-specific endpoint to get structured version records with release dates.Google News node: fetches RSS headlines as supporting display context (not sent to the LLM).

05 Stage 5 — Prioritization with Grounding
A structured output LLM ranks CVEs by CVSS score and release signals. Every ranked item must cite an evidence ID from the fetched data. A grounding validator checks all cited IDs exist in the fetched dataset and flags items that reference CVE IDs not present in any source.

SYSTEM ARCHITECTURE



RESULTS



Query Category	Query	Result	Time
Version Lookup	What is the latest patch for Firefox?	PASS	9.32s
CVE Lookup	Are there any critical CVEs in OpenSSL?	PASS	18.63s
Date-Specific Query	What was the Firefox version in March 2026?	PASS	24.12s
Out-of-Scope Detection	How do I install Python?	PASS	10.19s
CVE Lookup (multi-source)	Any CVEs affecting Chrome in last 2 months?	PASS	46.89s
Overall Accuracy		5/5 (100%)	24.83s avg

Pilot evaluation across 5 query categories. Each query checked against expected CVE IDs, version numbers, or redirect behavior. Results produced by running evaluate.py against live APIs.

DISCUSSION

Vendor matching eliminates the largest source of noise. Generic keyword search returns broad unrelated results. Querying the vendor-specific endpoint returns structured records with version numbers and release dates directly. The difference between "unknown" in the component field and "Firefox 150.0.0 released 2026-04-07" is entirely due to this step.

Deterministic sorting prevents LLM date confusion. Before sorting, release notes by date descending, the LLM would pick the first entry in the list regardless of recency. Sorting is a deterministic guardrail that costs zero tokens and removes an entire class of errors.

Reddit enrichment solves the vocabulary mismatch problem. Users phrase queries the way they talk, not the way APIs index data. Reading community posts bridges this gap without requiring a dedicated NLP model or named entity recognition library. The LLM reads context and expands terms.

Abstention is a feature. When both CVE and release note arrays are empty, the system returns "I don't know" rather than generating a plausible but unsupported answer. Out-of-scope queries are rejected before any data is fetched, confirmed correct in pilot evaluation.

Limitations. The system depends on data freshness from third-party APIs. NVD enforces a 120-day query window. The Groq free tier rate limit (100K tokens per day) constrains throughput for demo use.

FUTURE WORK

- Adaptive Thresholding: Automatically adjust the evidence sufficiency threshold based on query type. CVE queries require higher confidence than version lookup queries.
- Vendor Calibration Layer: Fine-tune decision boundaries separately for vendors with irregular release cadences (rolling releases vs. fixed schedules).
- Source Credibility Scoring: Assign weighted trust scores to NVD vs. vendor advisories vs. community posts before aggregating evidence.
- User Feedback Loop: Allow users to flag incorrect answers. Use corrections to retrain the orchestrator intent classifier.
- Multi-hop Reasoning: Chain release notes to advisories to patch dependencies before generating a final recommendation, rather than treating each source independently.
- Deploy a human-in-the-loop feedback mechanism allowing security analysts to correct mis-scored/bad patches, enabling continual fine-tuning of the priority scoring model in production.

CAIS 2026 · Workshop on Agentic Software Engineering Contact: idarshi@pacific.edu Poster · Portrait 24×36 in